

Case study 1: Unauthorized Nmap network scan

Analysis:

The student used Nmap to scan a Company's network without obtaining permission. Even though no systems were locked and no data was stolen, the scan was unauthorized. Ethical hackers must always obtain written permission before performing any security testing.

Ethical Analysis

- * violates ethical hacking principles
- * no prior authorization from the company
- * Ethical hacking requires consent and defined scope

Legal Analysis

Application Sections

- * Section 1: unauthorized access to computer systems may lead compensation
- * Section 66: unauthorized access done dishonestly or fraudulently is published
- * Section 32: Breach of Confidentiality and Privacy

Possible Legal Consequences

- * Police Complaint
- * Define the scope of testing
- * sign a legal agreement
- * Perform only authorized scans
- * Report vulnerability confidentially

Conclusion: The student's actions were unethical and potentially illegal because permission was not obtained before scanning.

Case Study 2: SAL injection vulnerability disclosure

Analysis: The researcher discovered a SAL injection vulnerability but immediately posted the exploit and PoC of concept online before informing the company. Attackers exploited the vulnerability and customer's data was leaked.

Ethical Analysis:

- * The researcher acted irresponsibly
- * Public disclosure before a fix increased the risk
- * Responsible disclosure protects users

Legal Analysis

Section 43: Unauthorized damage or access

Section 66: Computer related offences

Section 72: Breach of Confidentiality

Section 66(4)(b): if identity theft or

Responsible Vulnerability disclosure

- * Inform the organisation privately
- * Provide technical details securely
- * Give sufficient time to fix the issue
- * Publicly disclose only after the vulnerability is patched

Risks of Parameter Disclosure

- * Hackers exploit the vulnerability
- * Customer data theft
- * Financial loss
- * Loss of Customer trust
- * Damage to Company Reputation

Recommendation

Research should always follow Responsible Vulnerability Disclosure (or) Co-ordinated Vulnerability Disclosure

Conclusion:

Publishing exploit details before informing the company was unethical and increased cyber risk.

Case study 3: Phishing attack on employee

Types of Cyber attacks

Phishing

Analysis: The employee received a fake email pretending to be from the IT support team and entered login credentials on a fake website. The attacker used those credentials to access confidential company data.

Legal implications

Application Sections

- * Section 43: Unauthorized access
- * Section 66: Computer-related offences.

section 60C: clear identity theft

section 60D: checking by the institution using computer resources

Responsibilities of the organisation

- * Conduct employee awareness training
- * Enable multi-factor authentication MFA
- * use email security filters and spam
- * monitor security filters and spam
- * enforce strong Password Policies

Responsibility of the employee

- * verify suspicious emails before responding
- * never share passwords through email or
- * Report phishing attempts immediately
- follow Company Cybersecurity Policies

Preventive measures

- * Regular phishing awareness programs
- * MFA implementation
- * Email filtering and anti-phishing tools
- * Regular response procedure.

section 60C: can identify theft
section 60D: checking by penetration using Computer Resources
Responsibilities of the organisation

- * Conduct employee awareness training
- * Enable multi-factor authentication
- * use email security filters and spam
- * monitor security filters and spam
- * enforce strong Password Policies

Responsibility of the employee

- * verify suspicious emails before responding
- * never share passwords through email or
- * Report phishing attempts immediately
- * follow Company Cybersecurity Policies

Preventive measures

- * Regular phishing awareness programs
- * MFA implementation
- * Email filtering and anti phishing tools
- * Regular response procedure.

Case study on student exploits Bank Vulnerability before Reporting

Analysis: Although the student intended to report the vulnerability, accessing customer information without authorization is illegal and intentions do not make unauthorized access lawful.

Ethical hacking vs Unauthorized hacking

Ethical hacking

Written permission obtained

Defined scope

Legal

Helps improve security

Unauthorized hacking

No permission

Illegal access

Violates laws

Can lead to legal action

Relevant IT act, 2008:

Section 43: Unauthorized access and data extraction.

Section 66: Computer-related offences

* others

Proper Reporting Process

- * Do not exploit beyond minimal verification
- * Collect only enough evidence to prove the vulnerability
- * Contact the bank through official channels
- * maintain confidentiality
- * Give the bank reasonable time to fix the issue.
- * Avoid Public disclosure until the issue is resolved.

Conclusion:

The student's intention was ethical, but exploiting the vulnerability without authorization was not lawful. Ethical hackers must always obtain permission before testing systems.